

Executive Summary

This report evaluates the design, management, and security of Companies House's digital and data networks. As a national registry, Companies House processes millions of transactions and holds highly sensitive corporate data, which makes it a prime target for malicious actors. The report identifies risks, proposes segmented Zero Trust architecture, and recommends a range of controls including network segmentation, identity and access management with multi-factor authentication (MFA), security information and event management (SIEM), secure coding practices and staff training. The recommendations align with ISO 27001, the NIST Cybersecurity Framework, and NCSC guidance. The analysis is supported by tables, examples of real-world vulnerabilities (CVEs), and diagrams that illustrate the proposed network improvements.

1. Introduction

Public sector registries are high-value targets because they safeguard sensitive information that underpins trust in the national economy. Companies House holds ownership, filing and financial records for businesses across the UK. A breach could undermine public confidence, harm legitimate businesses, and lead to non-compliance with GDPR and other regulations. This report applies academic and practical cybersecurity concepts to assess the current state, design improvements, evaluate risks, and propose solutions. The structure of the report mirrors the module learning outcomes: research and explanation of network design, designing a secure network, evaluating vulnerabilities, and proposing improvements.

2. Research: How Networks Are Designed, Managed, and Secured

Network design follows well-established principles of scalability, resilience, segmentation, and security by design. Scalability ensures that systems can support seasonal peaks in filings without degradation. Resilience requires redundancy at all key points (routers, firewalls, servers). Segmentation through VLANs and DMZs ensures that services are separated, so compromise of one component does not expose the entire estate. Security by design involves adopting Zero Trust, encryption, and least-privilege access models.

Networks are managed through continuous monitoring, automation, and centralised logging. Routers and switches provide core routing and VLAN separation. Firewalls, IDS/IPS, and WAFs provide defensive layers. Cloud integration requires hybrid security solutions such as Azure AD for identity and Sentinel for SIEM. The best management practice is to combine monitoring (e.g. Splunk), configuration automation (e.g. Ansible), and logging into a central SOC. Identity and Access Management (IAM) is critical, particularly for privileged accounts, where MFA and controls reduce insider and external threats.

3. Design: A Simple Digital/Data Network

The design introduces segmented zones, redundancy, and layered defences. The VLAN and firewall tables below demonstrate how services are logically and securely separated. This design aims to prevent lateral movement, ensure sensitive data is isolated, and enable granular monitoring. The diagrams referenced later complement these tables by showing the high-level topology.

3.1 Sample VLAN / Addressing Plan:

VLAN ID	Name	Purpose	Subnet	Notes
10	DMZ	Public Web/API	10.0.10.0/24	WAF, LB
20	Application	Application servers	10.0.20.0/24	App security groups
30	Database	Sensitive data	10.0.30.0/24	DB encrypted, no Internet access
40	Users	Corporate workstations	10.0.40.0/24	802.1X, NAC
50	Admin	Privileged admin	10.0.50.0/24	Access via PAM

This table illustrates how each VLAN is dedicated to a function. For example, the database VLAN (30) is restricted and encrypted, ensuring filing data remains secure. By contrast, the DMZ VLAN (10) is exposed but protected by a WAF and load balancer. Segmentation reduces the attack surface and simplifies monitoring.

3.2 Sample Firewall Allowlist (representative):

Public sector case studies, such as HMRC and NHS, have shown that strict firewalling between zones is vital for preventing large-scale breaches. By adopting a zero-trust stance, where every flow must be explicitly authorised, Companies House ensures that attackers cannot exploit overlooked ports or protocols. The allowlist model is more secure than legacy blacklist approaches.

Source	Destination	Protocol / Port	Purpose	Direction
Internet	DMZ Web LB	TCP 443/80	Public web/API	Inbound
DMZ App	App Servers	TCP 8443	App traffic (HTTPS)	Internal
App Servers	DB Cluster	TCP 5432/3306	DB queries	Internal
Admin VLAN	App Servers	TCP 22/3389	Admin (via jump host)	Internal
All	SIEM	UDP 514 / API	Log ingest	Internal -> SOC

This firewall allowlist has permitted flows. Only HTTPS is exposed externally. Applications communicate securely with the database over restricted ports & administrators must connect via a jump host. Logs from all segments are directed to the SIEM, enabling central monitoring. This aligns with best practice of default deny and least privilege.

4. Evaluation: Vulnerabilities and Risks

The table outlines threats, impacts, and mitigations, showing how poor segmentation, patching gaps, and weak authentication create high risks for public sector services like Companies House. These are prioritised in a simple risk register. The risk matrix illustrates likelihood versus impact for stakeholders.

Companies House is most exposed to **segmentation weaknesses** and **unpatched systems**, which enable lateral movement or CVE exploitation. **Authentication and encryption gaps** also rank highly due to regulatory and reputational risks.

Risk Matrix Summary

Risk	Description	Potential Impact	Likelihood	Impact	Severity (L × I)	Risk Level	Possible Mitigation
------	-------------	------------------	------------	--------	------------------	------------	---------------------

Weak Firewall Implementation	Insufficient separation between DMZ and internal networks	Data exposure; lateral movement	5	5	25	Critical	Implement VLANs, NGFW, micro-segmentation
Phishing & Social Engineering	Human-targeted attacks	Credential theft; initial access	4	4	16	High	Training, phishing simulations, secure email gateway
Unencrypted Data	Data at rest/in transit not encrypted	Data interception, GDPR breach	3	5	15	High	TLS 1.3, DB encryption, VPNs
Endpoint Security	Weak device updates, antivirus, etc.	Malware infections, ransomware	3	3	9	Moderate	EDR, regular updates, endpoint hardening
Guest WiFi Risks	Shared with internal network	Breach of internal systems	2	3	6	Low	Separate VLAN, network isolation

It's a **risk matrix for the Companies House Network**, showing various cybersecurity risks plotted by **Likelihood (1 = Low, 5 = High)** and **Impact (1 = Low, 5 = High)**. The matrix uses a colour gradient from **yellow (low severity)** to **dark red (high severity)**, with a scale from **0 to 25** on the right:

4.1 Example CVEs (illustrative)

Including CVEs in this report provides a practical connection between abstract risks and

real-world exploits. Mapping vulnerabilities to patches and mitigations demonstrates a proactive security stance. It also supports board-level risk reporting, where senior leaders increasingly expect quantified and evidenced risk data.

CVE ID	Affected Component	Impact	Mitigation
CVE-2017-0144	SMB (EternalBlue)	Wormable RCE; ransomware spread	Patch OS; disable SMBv1; network segmentation
CVE-2021-26855	Microsoft Exchange (ProxyLogon)	Auth bypass; RCE	Apply MS patches; monitor indicators; EDR
CVE-2021-41773	Apache HTTPD Path Traversal	File disclosure/RCE on unpatched servers	Patch Apache; WAF; input validation

This CVE table grounds the analysis in real-world exploits. EternalBlue, for example, was leveraged in the WannaCry outbreak that disrupted the NHS. ProxyLogon shows the risk to public-sector email servers, and Apache path traversal reflects common web server issues. By proactively patching and monitoring, Companies House can avoid becoming the next victim of high-profile attacks.

5. Proposed Security Solutions

To strengthen security, organisations must embed secure coding practices throughout the software development lifecycle. Developers should be trained in standards like the OWASP Top 10 to avoid common vulnerabilities, and automated code scanning tools (such as SonarQube or Checkmarx) should be integrated into CI/CD pipelines for early detection of issues. Peer reviews are essential for critical changes, and secure coding should be reinforced through ongoing training, threat modelling, and the presence of security champions.

Identity and Access Management (IAM) should go beyond multi-factor authentication (MFA). Implementing role-based access control (RBAC) ensures users only have necessary permissions, while periodic privilege reviews prevent privilege creep. These measures, combined with strong authentication, help maintain compliance and reduce insider threats.

Mitigation strategies should prioritise high-risk areas: network segmentation, patch management, IAM, SIEM (Security Information and Event Management), and EDR (Endpoint Detection and Response). Together, these technical and organisational controls create a layered defence, limiting lateral movement, closing vulnerabilities, controlling access, providing real-time monitoring, and enabling rapid response to threats.

Figure 3a: Companies House Network (Before) – Flat architecture with limited segmentation and monitoring.

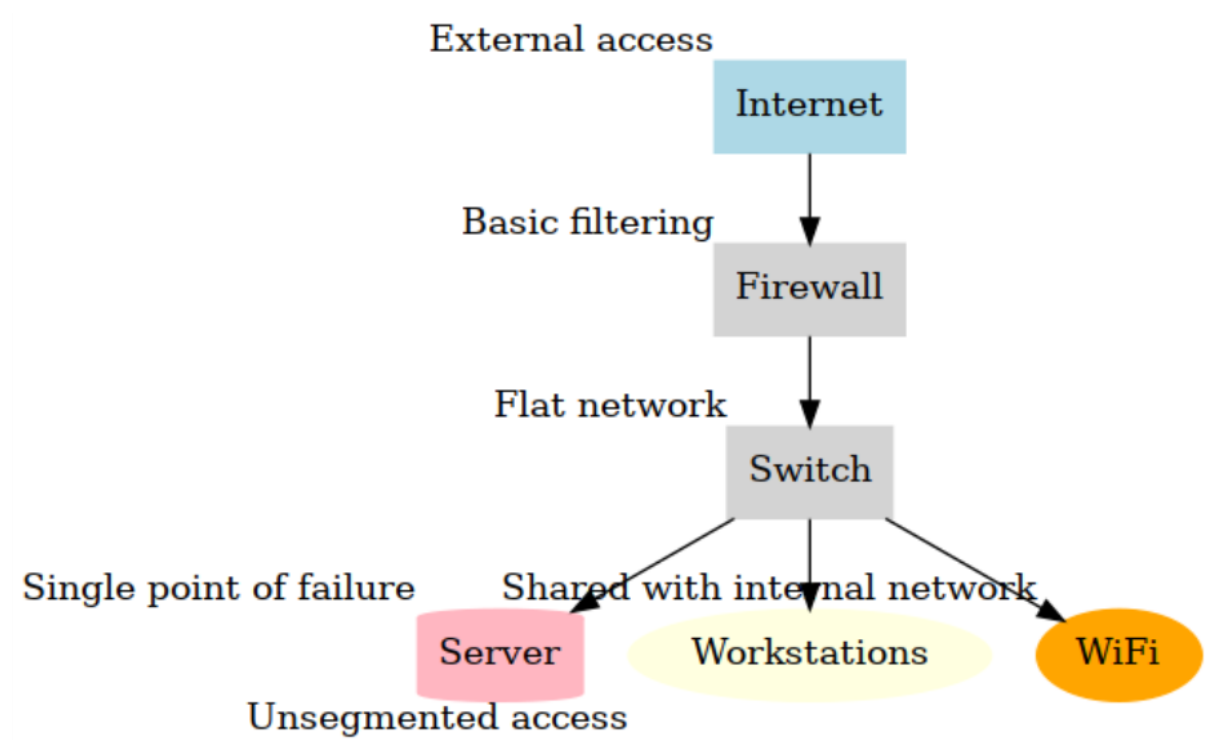
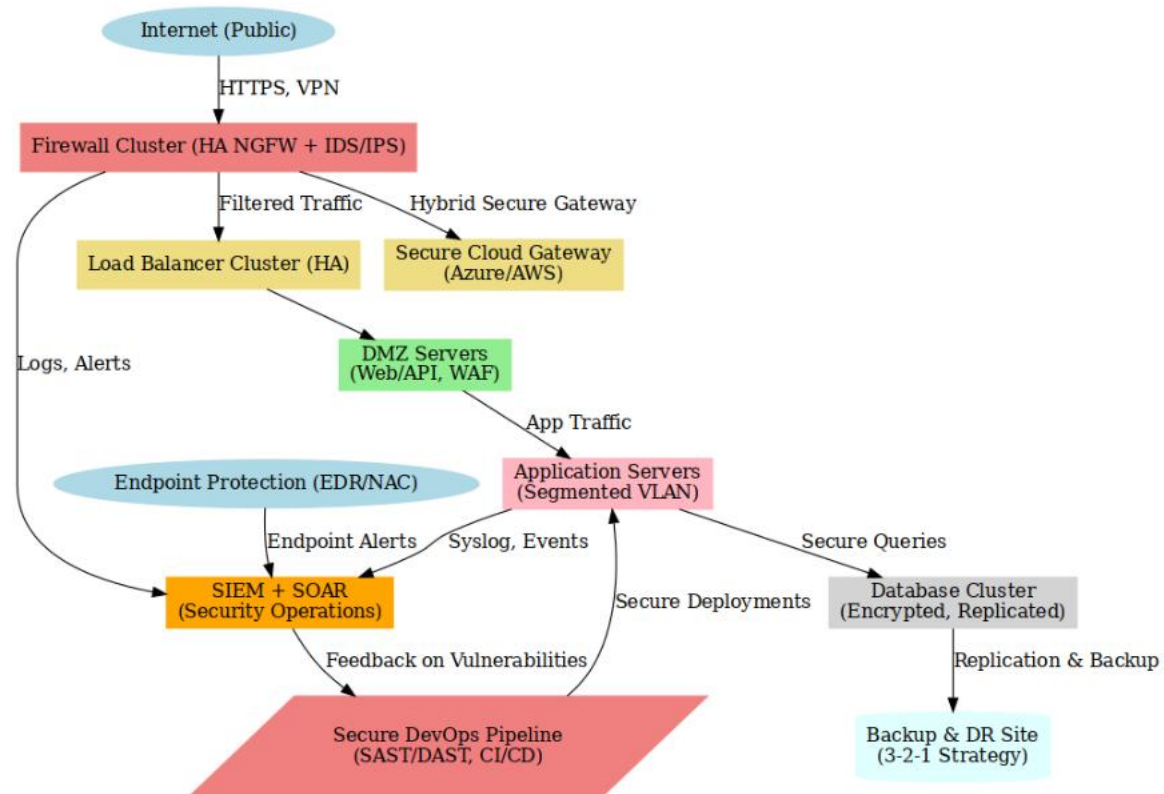


Figure 3b: Companies House Network (After) – Segmented and monitored design with Zero Trust controls.



The improved "After" architecture introduces a multi-layered, defence-in-depth approach:

- **Internet (Public):** All external access is strictly controlled and encrypted (HTTPS, VPN).
- **Firewall Cluster (HA NGFW + IDS/IPS):** High-availability next-generation firewalls with integrated intrusion detection and prevention systems filter and inspect all incoming and outgoing traffic, blocking malicious activity before it reaches internal resources.
- **Load Balancer Cluster (HA):** Ensures high availability and distributes traffic to DMZ servers, preventing overload and enabling seamless failover.
- **DMZ Servers (Web/API, WAF):** Public-facing services are isolated in a demilitarised zone, protected by a web application firewall (WAF) to block common web attacks.

- **Application Servers (Segmented VLAN):** Internal applications are hosted on segmented VLANs, reducing the risk of lateral movement if one server is compromised.
- **Database Cluster (Encrypted, Replicated):** Sensitive data is stored in encrypted, replicated databases, ensuring both confidentiality and availability.
- **Backup & DR Site (3-2-1 Strategy):** Regular, encrypted backups are maintained at a disaster recovery site, following the 3-2-1 rule (three copies, two media, one offsite) for resilience against ransomware and data loss.
- **SIEM + SOAR (Security Operations):** Centralised security information and event management (SIEM) collects logs and telemetry from across the network, while security orchestration, automation, and response (SOAR) enables rapid, automated incident response.
- **Endpoint Protection (EDR/NAC):** Endpoints are protected by advanced detection and response tools, with network access control (NAC) ensuring only compliant devices can connect.
- **Secure Cloud Gateway (Azure/AWS):** Hybrid workloads are protected by secure gateways, enabling safe integration with cloud services.
- **Secure DevOps Pipeline (SAST/DAST, CI/CD):** The DevOps pipeline incorporates static and dynamic application security testing, ensuring vulnerabilities are caught before deployment. Feedback from SIEM/SOAR is used to continuously improve code security.

This architecture aligns with NIST CSF, ISO/IEC 27001, and NCSC Cyber Essentials Plus, providing strategic assurance and business resilience. The layered approach ensures that even if one control fails, others remain to protect the organisation.

Feature	Before (Less Secure)	After (More Secure)
Segmentation	Flat network via single switch	Segmented via Next-Gen Firewall and DMZ
Security	Basic firewall	Advanced firewall, encrypted DB server
Monitoring	None	SIEM for real-time monitoring
WiFi Access	Shared with internal network	Isolated guest WiFi
Server Architecture	Single server for all services	Layered: Web, App, and DB servers

Highlighted Case Study Box – NHS WannaCry (2017)

Case Study: NHS WannaCry (2017)

The WannaCry ransomware outbreak in May 2017 crippled large parts of the UK's National Health Service (NHS). The attack exploited the EternalBlue vulnerability (MS17-010) in unpatched Windows systems. Because many NHS trusts operated **flat networks with limited segmentation or monitoring**, the malware spread rapidly across environments. This disruption led to cancelled appointments, delayed treatments, and an estimated financial impact of **£92 million** (NAO, 2018).

5.1 KPIs and SLAs (examples)

Domain	KPI / SLA	Target
Availability	Core network uptime	>= 99.95% monthly
Security	Critical CVE remediation time	<= 7 days
Detection	Mean Time To Detect (MTTD)	< 10 minutes
Response	Mean Time To Restore (MTTR)	< 60 minutes

To measure and govern security effectively, **Key Performance Indicators (KPIs)** and **Service Level Agreements (SLAs)** must align with business objectives.

- **Patch compliance rates:** % of systems updated within 14 days of release.
- **Mean Time to Detect (MTTD)** and **Mean Time to Respond (MTTR):** benchmarks for how quickly incidents are identified and remediated.
- **Phishing simulation click rates:** track staff awareness improvements.
- **Uptime SLA (e.g., 99.95%):** ensures service continuity for critical public-facing platforms.

By regularly reporting these KPIs and SLA outcomes to the **executive board**, Companies House ensures cybersecurity performance is tied to **risk appetite and governance frameworks**. This not only drives accountability but also enables informed, strategic decision-making at the highest level.

6. Conclusion

Ultimately, cybersecurity investment is not just a technical necessity but a strategic enabler. By ensuring its networks are resilient, Companies House protects public trust, enables secure digital transformation, and contributes to national economic resilience. The proposed architecture and practices can serve as a model for other public sector bodies facing similar challenges.

This report demonstrates that Companies House can significantly improve its cybersecurity posture through layered defences, Zero Trust principles, and investment in IAM, SIEM, and staff training. Tables and diagrams support the analysis, showing both the technical detail (VLANs, firewall rules, CVEs) and the strategic outcomes (KPIs, risk reduction). The proposed roadmap not only improves resilience and compliance but also strengthens trust in the organisation's role as a guardian of corporate data.

References

- Davies, G. (2020) **Networking Fundamentals**. Birmingham: Packt Publishing.
- Barker, J. (2020) **Confident Cyber Security: How to get Started in Cybersecurity and Future Proof your Career**. London: Kogan Page.
- Calder, A. (2020) **The Cyber Security Handbook**. Ely: IT Governance Publishing.
- Hodgson, C. (2019) **Cyber Risk Management: Prioritise Threats, Identify Vulnerabilities and Apply Controls**. Abingdon: Routledge.

- ISO/IEC (2013) *Information Security Management Systems – Requirements (ISO/IEC 27001:2013)*. Geneva: ISO.
- NIST (2018) *Framework for Improving Critical Infrastructure Cybersecurity*. Gaithersburg: NIST.
- OWASP (2021) *OWASP Top 10: The Ten Most Critical Web Application Security Risks*. OWASP Foundation.